

TAREA IC01

Auditoría Interna de Prevención.

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Diseño del esquema de una Empresa Ficticia.....	3
Respuestas 1	5
Apartado 2: Detalle de los Activos Clave que se deberán auditar.....	7
Respuestas 2	8
Apartado 3: Comprobación prioritaria a efectuar para cada uno de los activos anteriores.....	9
Respuestas 3	10
Apartado 4: Auditoría prioritaria por activo (una por cada activo, sin repetir tipo).	12
Respuestas 4	14

Detalles de la tarea de esta unidad

- Una auditoría interna en materia de prevención resulta fundamental para una organización, pues permite conocer el estado de los activos antes de la aparición de los incidentes, dejando margen de tiempo suficiente para solucionar las posibles debilidades y vulnerabilidades.
- Además, una vez se efectúa este tipo de auditoría, también es el momento de implantar un mecanismo de mantenimiento continuo de la protección y la calidad de la información, mediante un esquema de mejora continua o un modelo de madurez.
- En esta tarea habrá que diseñar un procedimiento de auditoría para una empresa ficticia, cuyo diseño parcial formará parte también de la práctica.

Apartado 1: Diseño del esquema de una Empresa Ficticia

Información básica para diseñar el esquema de la empresa:

- La empresa ficticia es una **joven PYME industrial** dedicada a la fabricación de repuestos para el sector automotriz. Como empresa orientada a la producción y gestión de inventarios, utiliza tanto Tecnologías de la Información (TI) para sus operaciones administrativas y comerciales, como Tecnologías de Operación (OT) para la gestión y control de los procesos fabriles. Dado que esta empresa depende de sistemas de información para la continuidad de sus operaciones y protección de datos, se ha establecido una arquitectura de red basada en tres zonas principales, conocidas como estructura en trípode.
- La empresa se organiza en tres bloques principales que permiten separar los activos de TI y OT y gestionar los accesos de manera controlada:
 1. **LAN (Red Interna de Gestión Empresarial):** Esta red interna incluye todos los sistemas y servicios necesarios para la gestión empresarial y el soporte administrativo. Entre sus activos se encuentran los puestos de trabajo de los empleados, tanto locales como remotos, y los sistemas de bases de datos y almacenamiento para el ERP (Enterprise Resource Planning), utilizados para el manejo de la información económica y financiera. Además, aquí se encuentran los sistemas de análisis avanzados, como Big Data, IA y Machine Learning, empleados para mejorar la toma de decisiones estratégicas.
 2. **DMZ (Zona Desmilitarizada):** Esta zona se encuentra segmentada de la red interna y la red externa (Internet), y su función principal es albergar los servicios que deben estar expuestos parcialmente a Internet. La DMZ de la empresa contiene el Centro de Operaciones de Seguridad (SOC), desde donde se monitorizan los eventos de seguridad; un IDS (Sistema de Detección de Intrusiones) y SIEM (Gestión de Información y Eventos de Seguridad) para la detección y gestión de incidentes; y el NAS (Network Attached Storage) y Vault,

que almacenan documentos de diseño y planos protegidos. Adicionalmente, en esta zona se encuentran un portal web para la presencia pública de la empresa y un servidor de laboratorio destinado a pruebas de software y aplicaciones internas.

3. **Smart Factory (Red de Operación Fabril, aislada de Internet):** En esta zona se agrupan todos los sistemas relacionados con la producción y el control de los procesos fabriles. La red de la Smart Factory incluye el sistema ERP y el MES (Manufacturing Execution System), que se usan para la gestión de la producción y el control del inventario. Además, en esta zona se encuentra el sistema SCADA para la supervisión y control en tiempo real de los procesos industriales, los PLC (Controladores Lógicos Programables) que gestionan la maquinaria automatizada y los dispositivos fabriles como sensores y actuadores. Estos activos no están expuestos a Internet para reducir riesgos de ciberseguridad y asegurar la continuidad operativa.

Con la información proporcionada deberás efectuar las siguientes tareas:

- Crear una lista con todos los activos de la empresa detectados en cada una de las zonas.
- Crear un Diagrama de Bloques gráfico de la Empresa Ficticia según la estructura pedida en el que se distribuyan los activos de la lista anterior, es decir, un esquema general de los equipos distribuidos en la red según esta estructura en trípode.

Para la realización de este diseño se puede usar la herramienta que se considere más idónea. Se recomienda el uso de **draw.io** que viene integrada en el Drive de Google o se puede optar por otras alternativas integradas en suites ofimáticas.

Una vez completado el diagrama, exporta la imagen del mismo. Este diagrama formará parte de la solución que entregarás en este apartado.

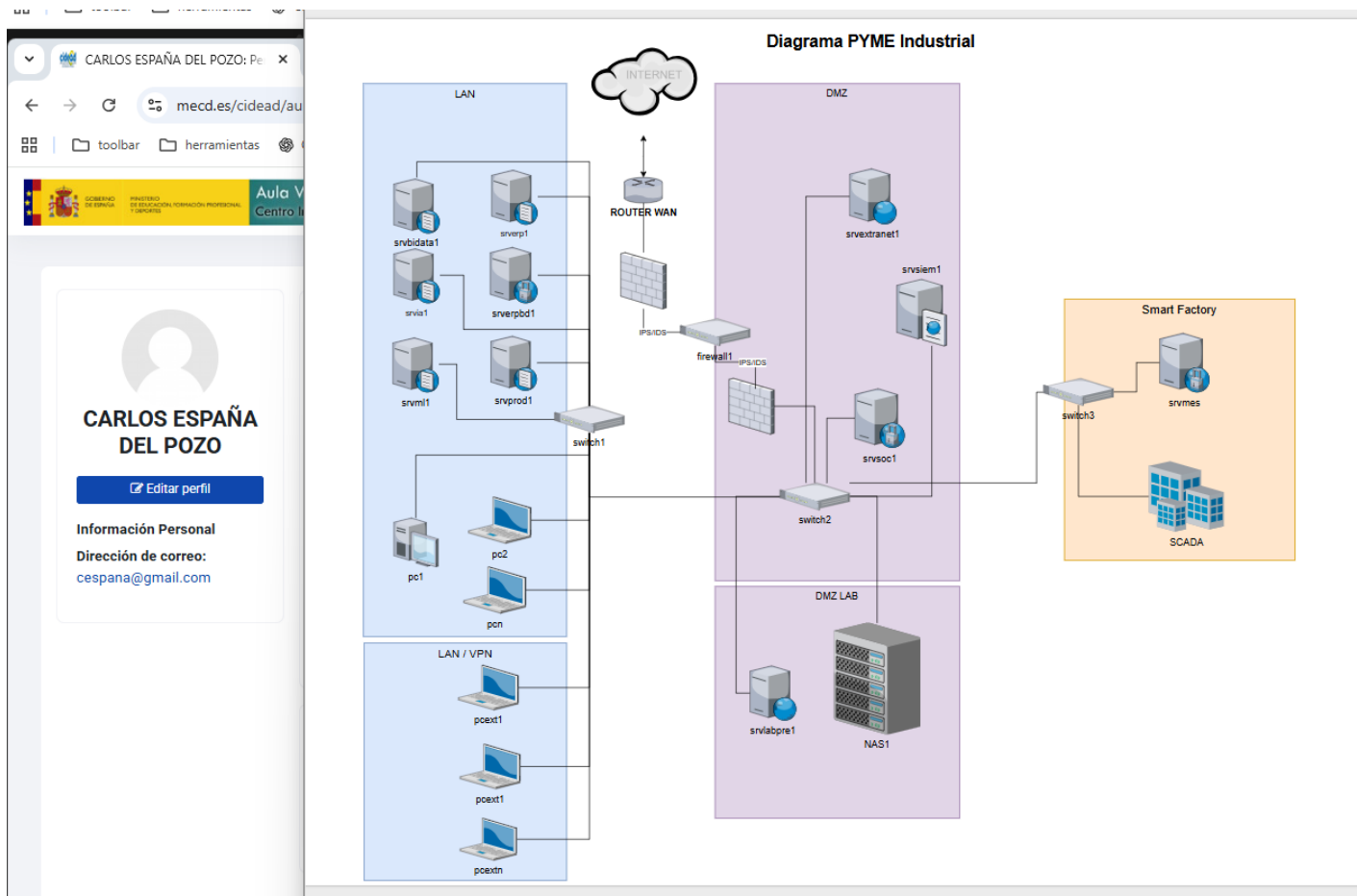
Respuestas 1

Una vez revisada la información facilitada y en base al decálogo básico de seguridad, procedemos a realizar un inventario de todos nuestros activos que pasaremos después a nuestro sistema de CMDB, como fuente única de conocimiento y para poder tener un control más específico de nuestros activos, sus servicios y las relaciones de estos además de tener un control de **la superficie de exposición** a las amenazas, pues no sólo hay que implementar medidas de seguridad que protejan el acceso a la información, sino que hay que determinar los servicios que son estrictamente necesarios.

	A	B	C	D
1	ZONA	Nombre Host	Dirección IP	
2	LAN	switch1	192.168.1.1	
3	LAN	srvprod1	192.168.1.6	
4	LAN	srverp1	192.168.1.7	
5	LAN	srverpbd1	192.168.1.8	
6	LAN	srvia1	192.168.1.9	
7	LAN	srvbigdata1	192.168.1.10	
8	LAN	srvml1	192.168.1.11	
9	LAN	pc1	192.168.10.10	
10	LAN	pc2	192.168.10.11	
11	LAN	pcn	192.168.10.12	
12	LAN	pcext1	192.168.10.21	
13	LAN	pcext2	192.168.10.22	
14	LAN	pcextn	192.168.10.23	
15				
16	DMZ	Router WAN	172.16.1.1	
17	DMZ	firewall1	172.16.1.5	
18	DMZ	switch2	172.16.1.10	
19	DMZ	srvsoc1	172.16.1.11	
20	DMZ	srvsiem1	172.16.1.13	
21	DMZ	srvextranet1	172.16.1.14	
22	DMZ LAB	NAS1	172.16.2.1	
23	DMZ LAB	svrlabpre1	172.16.2.2	
24				
25	Smart Factory	switch3	10.0.0.10	
26	Smart Factory	scada	10.0.0.11	
27	Smart Factory	srvmes	10.0.0.12	
28				

Este sería el diagrama de Estructura en Trípodé -Topología de Red de la empresa.

Dividido por colores los tres bloques principales y los elementos perimetrales de comunicaciones.



Apartado 2: Detalle de los Activos Clave que se deberán auditar.

Para llevar a cabo una auditoría efectiva, es fundamental identificar y documentar los activos clave de la empresa ficticia. Estos activos comprenden tanto elementos de hardware como de software que juegan un papel esencial en el funcionamiento seguro y eficiente de la infraestructura de TI y OT de la organización.

- Para este apartado, deberás realizar un inventario de los activos clave, recopilando la información necesaria en una tabla para los activos que consideres necesarios, tomando un activo por cada zona (LAN, DMZ, Smart Factory) más un activo transversal que pudiera estar en más de una zona o sea perimetral.
- Completa la siguiente tabla de inventario para cada uno de los activos seleccionados. La tabla debe incluir los datos esenciales de cada activo, tales como:

Zona	Nombre Activo	Dirección IP/Rango de IP	Sistema Operativo	Modelo de Máquina	Función en la Empresa	Observaciones
Perimetral	Router Frontera	192.168.1.1	Askey	RTF3505VW	Router de conexión a Internet	LAN, WiFi habilitado

- Este inventario de activos será esencial para los siguientes apartados, donde se definirán las comprobaciones de seguridad y los procedimientos de auditoría específicos para cada uno de estos activos.

Respuestas 2

Este sería el inventario resumen solicitado de los activos de la compañía, comentar que los activos de comunicaciones switch tendrán varios direccionamientos ip's para establecer comunicación entre ellos.

ZONA	Nombre Host
LAN	srvprod1
Perimetral	Router WAN
Perimetral	firewall1
DMZ LAB	NAS1
Smart Factory	scada

Tabla detallada.

ZONA	Nombre Host	Dirección IP	Sistema Operativo	Modelo de máquina	Función en la empresa	Observaciones
LAN	switch1	192.168.1.1	Forti	Fortinet FortiSwitch FS-3032E	Switch capa 3 LAN	LAN, Segmentación
LAN	srvprod1	192.168.1.6	Rhel 9	Dell PowerEdge R740	Servidor principal LDAP	LAN, WiFi Inhabilitada
LAN	srverp1	192.168.1.7	Rhel 9	Dell PowerEdge R740	Servidor ERP	LAN, WiFi Inhabilitada
LAN	srverpbd1	192.168.1.8	Rhel 9	Dell PowerEdge R740	Servidor BD ERP	LAN, WiFi Inhabilitada
LAN	srvia1	192.168.1.9	Rhel 9	Dell PowerEdge R760 (GPU)	Servidor IA	LAN, WiFi Inhabilitada
LAN	srvm1	192.168.1.10	Rhel 9	Dell PowerEdge R740	Servidor Big Data	LAN, WiFi Inhabilitada
LAN	pc1	192.168.10.10	Windows 11	Dell OptiPlex 7090	Servidor Machine Learning	LAN, WiFi Inhabilitada
LAN	pc2	192.168.10.11	Windows 11	Dell Latitude 5520	Puesto Empleados	LAN, WiFi
LAN	pcn	192.168.10.12	Windows 11	Dell Latitude 5520	Puesto Empleados	LAN, WiFi
LAN	pcext1	192.168.10.21	Mac os 15	MacBook Pro M2	Puesto Empleados Externos	VPN, WiFi
LAN	pcext2	192.168.10.22	Windows 11	Dell Latitude 5520	Puesto Empleados Externos	VPN, WiFi
LAN	pcextn	192.168.10.23	Windows 11	Dell Latitude 5520	Puesto Empleados Externos	VPN, WiFi
Perimetral	Router WAN	172.16.1.1	Forti	Fortinet FortiGate 200E	Conexión a Internet	LAN y Conexión a internet
Perimetral	firewall1	172.16.1.5	Forti	Fortinet FortiGate 600E	Firewall IDS/IPS	LAN, WiFi Inhabilitada
DMZ	switch2	172.16.1.10	Forti	Fortinet FortiSwitch FS-3032E	Switch capa 3 DMZ	LAN, Segmentación
DMZ	srvsoc1	172.16.1.11	Rhel 9	Dell PowerEdge R740	Servidor Monitorización SOC	LAN, WiFi Inhabilitada
DMZ	srvsiem1	172.16.1.13	Rhel 9	Dell PowerEdge R740	Servidor SIEM	LAN, WiFi Inhabilitada
DMZ	srvxtranet1	172.16.1.14	Rhel 9	Dell PowerEdge R740	Servidor Portal extranet	LAN, WiFi Inhabilitada
DMZ LAB	NAS1	172.16.2.1	emc	EMC Unity XT 380	NAS / VAULT	NAS y SAN
DMZ LAB	srvalbpre1	172.16.2.2	Rhel 9	Dell PowerEdge R740	Servidor de pruebas	LAN, WiFi Inhabilitada
Smart Factory	switch3	10.0.0.10	Forti	Fortinet FortiSwitch Rugged FS-124D	Switch capa 3 Smart Factory	LAN, Segmentación
Smart Factory	scada	10.0.0.11	WinCC*	Siemens IPC647G Industrial PC	SCADA	LAN, Sin acceso a Internet
Smart Factory	srvmes	10.0.0.12	Rhel 9	Dell PowerEdge R740	Servidor MES	LAN, WiFi Inhabilitada

Apartado 3: Comprobación prioritaria a efectuar para cada uno de los activos anteriores.

Una vez que se ha realizado el inventario de los activos clave, es necesario definir las comprobaciones de seguridad que se deben efectuar sobre cada uno de ellos. Estas comprobaciones buscan identificar vulnerabilidades y asegurar que los activos cumplen con las medidas de protección adecuadas para minimizar riesgos de ciberseguridad.

A continuación, se detallan algunas de las principales comprobaciones de seguridad aplicables a los activos de la empresa ficticia:

- Sistemas Antimalware: Verificación de software antivirus y antimalware.
- Gestión de Permisos: Revisión de permisos de acceso y privilegios de usuario.
- Cumplimiento Legal (Compliance): Asegurar que el activo cumple con normativas de ciberseguridad.
- Prevención de Fraude y Fuga de Datos: Comprobación de medidas de protección contra fraudes y exfiltración de datos.
- Sistema de Actualizaciones: Verificación de políticas de actualización y parches de seguridad.
- Monitorización de Recursos: Revisión de herramientas de monitoreo en tiempo real de rendimiento y actividad.
- Protección de Datos / Propiedad Intelectual (PD/PI): Asegurarse de la protección de datos sensibles y propiedad intelectual.

Para cada activo seleccionado en el apartado anterior tienes que elegir una de las comprobaciones de seguridad aplicables de esta lista mostrada. Cada activo debe tener relacionada una comprobación diferente, por lo que no pueden repetirse. Para cada par de activo-comprobación se debe rellenar una ficha con la siguiente información:

- Zona.
- Activo.
- Comprobación a realizar.
- Objetivo de la comprobación.
- Herramientas para efectuar comprobación.
- Criterio de aceptación de la comprobación (PASS/FAIL).

**Ejemplo de ficha (basado en el activo de referencia del Apartado 2):*

- **Zona:** DMZ (Perímetro)
- **Activo:** Router Frontera — Askey RTF3505VW — 192.168.1.1
- **Comprobación a realizar:** Monitorización y registros centralizados (SIEM/logs)
- **Objetivo de la comprobación:** Garantizar que el router perimetral envía registros de tráfico/seguridad al SIEM con retención adecuada y que existen alertas operativas ante eventos críticos.
- **Herramientas:** Panel Askey (Syslog), SIEM (p. ej., Wazuh/Elastic/Graylog).
- **Procedimiento:**
 - Validar en el panel del Askey la configuración de Syslog remoto (IP/puerto del SIEM, facility/severity, hora sincronizada).
 - En el SIEM, confirmar la fuentes de logs del router y la retención configurada (≥ 90 días).

- Generar un evento de prueba (p. ej., intento de acceso fallido a la consola o un ping bloqueado por firewall) y verificar su ingestión.
- Comprobar que los campos clave (origen/destino, acción, timestamp) se parsean correctamente y son consultables.
- **Criterio de aceptación (PASS/FAIL):** PASS si los eventos llegan al SIEM en < 1 minuto, con campos parseados y retención ≥ 90 días; FAIL si no se reciben, no se parsean o no existe retención definida.

Respuestas 3

A continuación, detallo las comprobaciones de seguridad de los activos clave:

srvprod1

- **Zona:** LAN
- **Activo:** Servidor principal LDAP — Dell PowerEdge R740 — 192.168.1.6
- **Comprobación a realizar:** Gestión de permisos (control de acceso y privilegios)
- **Objetivo de la comprobación:** Garantizar que solo usuarios administrativos autorizados pueden gestionar el servidor LDAP y que los permisos siguen el principio de mínimo privilegio.
- **Herramientas:** /etc/passwd, ldapsearch (herramientas ldap), logs de seguridad y auditoría, bastionado ssh (iptables, nftables).
- **Procedimiento:**
 - Revisar lista de usuarios con acceso sudo y SSH al servidor.
 - Confirmar que solo el personal autorizado aparece en /etc/sudoers.
 - Comprobar logs de accesos y actividad administrativa.
- **Criterio de aceptación (PASS/FAIL):** PASS si solo usuarios autorizados tienen privilegios, sudo está controlado y no hay accesos dudosos.; FAIL si existen cuentas huérfanas, sudo excesivo o accesos no justificados.

router WAN

- **Zona:** Perimetral DMZ
- **Activo:** Conexión a Internet — Fortinet FortiGate 200E — 172.16.1.1
- **Comprobación a realizar:** Sistema de actualizaciones (firmware y firmas de seguridad)
- **Objetivo de la comprobación:** Verificar que el router se encuentra actualizado con la última versión recomendada del firmware.
- **Herramientas:** Consola FortiGate (GUI/CLI).
- **Procedimiento:**
 - Acceder a GUI y verificar versión de firmware instalada.
 - Comparar con versión recomendada por Fortinet.
- **Criterio de aceptación (PASS/FAIL):** PASS si firmware ≥ versión recomendada y módulos de seguridad actualizados; FAIL si versión obsoleta o firmas desactualizadas.

firewall1

- **Zona:** Perimetral DMZ
- **Activo:** Firewall IDS/IPS — Fortinet FortiGate 600E — 172.16.1.5
- **Comprobación a realizar:** Monitorización de recursos (y alertas en tiempo real).
- **Objetivo de la comprobación:** Garantizar la supervisión del rendimiento, tráfico, amenazas y capacidad del firewall para prevenir ataques, fallos o saturación.
- **Herramientas:**
 - FortiView / System Monitor.
 - FortiAnalyzer / Syslog.
- **Procedimiento:**
 - Comprobar CPU, RAM, sesiones activas, y throughput.
 - Revisión de logs en FortiView y envío a SIEM.
 - Realizar test de generación de eventos de seguridad.
- **Criterio de aceptación (PASS/FAIL):** PASS si el firewall reporta métricas, alerta correctamente y no hay saturación; FAIL si no hay logs, métricas ausentes o recursos al límite.

NAS1

- **Zona:** DMZ LAB
- **Activo:** NAS / VAULT — EMC Unity XT 380 — 172.16.2.1
- **Comprobación a realizar:** Protección de Datos / Propiedad Intelectual (PD/PI).
- **Objetivo de la comprobación:** Asegurar que la información almacenada (copias, datos generales, datos críticos) está cifrada, replicada y protegida con acceso restringido.
- **Herramientas:**
 - Consola EMC Unisphere
 - Logs NAS
 - Configuración CIFS/NFS ACLs propias.
- **Procedimiento:**
 - Revisar configuración de cifrado y snapshots.
 - Validar control de acceso y permisos a volúmenes.
 - Comprobar políticas de retención y planes de recuperación.
 - Confirmar logging de accesos al almacenamiento.
- **Criterio de aceptación (PASS/FAIL):** PASS si datos están cifrados, con permisos mínimos y políticas de backup aplicadas; FAIL si accesos abiertos, sin cifrado o sin retención protegida.

scada

- **Zona:** Smart Factory
- **Activo:** SCADA — Siemens IPC647G — 10.0.0.11
- **Comprobación a realizar:** Prevención de fraude y fuga de datos (protección OT).
- **Objetivo de la comprobación:** Garantizar que el sistema SCADA está protegido frente a manipulación de procesos, acceso remoto no autorizado y exfiltración de datos industriales.
- **Herramientas:**
 - WinCC audit logs
 - Revisión de puertos y servicios
 - Políticas USB y medios extraíbles.

- **Procedimiento:**
 - Validar aislamiento de red y no acceso a Internet.
 - Revisar logs de WinCC y cambios en parámetros de control.
 - Comprobar bloqueo de USB y restricciones de dispositivos.
 - Revisar usuarios y accesos remotos deshabilitados.
- **Criterio de aceptación (PASS/FAIL):** PASS si está aislado, logs habilitados, USB bloqueado y accesos controlados; FAIL si hay USB habilitado o trazas de comunicación no autorizada.

Apartado 4: Auditoría prioritaria por activo (una por cada activo, sin repetir tipo).

Selecciona para cada uno de los cuatro activos (LAN, DMZ, OT y Transversal) **un único tipo de auditoría**, priorizando la que mejor cubra el riesgo principal del activo. No puede repetirse el tipo de auditoría entre activos. La elección puede estar **alineada** con los posibles hallazgos del Apartado 3.

Tipos de auditoría disponibles (elige 1 diferente por activo):

- **Test de penetración (Hacking Ético):** identificación de vulnerabilidades explotables (en laboratorio, con alcance controlado).
- **Auditoría de red:** revisión de diseño/segmentación, enrutamiento y servicios expuestos.
- **Seguridad perimetral:** validación de controles en frontera (firewall, WAF, VPN, reglas y gestión).
- **Auditoría web:** revisión de aplicaciones/servicios web (sin explotación; baseline de seguridad).
- **Auditoría forense:** procedimiento post-incidente y preservación de evidencias.
- **Auditoría legal (Compliance):** adecuación a normativa aplicable (p. ej., protección de datos y privacidad).
- **Revisión de logs:** análisis de registros y correlación en SIEM para detectar anomalías.

Reglas: (1) una auditoría por activo; (2) las cuatro auditorías elegidas deben ser todas distintas.

Campos a cumplimentar en la ficha (por cada par activo–auditoría):

- **Zona:** LAN / DMZ / OT / Transversal.
- **Activo:** exactamente como en el inventario del Apartado 2.
- **Tipo de auditoría seleccionada:** (una de la lista anterior, sin repetir entre activos).
- **Justificación de elección (2–4 líneas):** vincula la elección con el principal riesgo o motivo.
- **Alcance y limitaciones:** qué se incluye/excluye, rangos IP/URLs, entorno (lab/producción), restricciones de intrusividad.
- **Procedimiento (3–7 pasos):** pasos concretos y reproducibles para ejecutar la auditoría.
- **Herramientas:** herramienta principal (y opcionalmente una de apoyo).
- **Criterios de aceptación (PASS/FAIL):** condiciones medibles (3–5 ítems) que determinen el resultado.

**Ejemplo de auditoría (basado en el activo de referencia del Apartado 2):*

- **Zona:** DMZ (Perímetro)
- **Activo:** Router Frontera — Askey RTF3505VW — 192.168.1.1
- **Tipo de auditoría seleccionada:** Seguridad perimetral
- **Justificación de prioridad (2–4 líneas):** Dispositivo de frontera con impacto directo en la superficie de exposición de toda la organización. Cerrar servicios no necesarios, validar reglas y asegurar la gestión restringida reduce el riesgo de intrusiones y facilita la detección temprana (coherente con hallazgos del Apartado 3).
- **Alcance y limitaciones:** Revisión de configuración (firewall/NAT/gestión), validación de superficie expuesta desde una red externa *simulada* y verificación de gestión segura desde red de administración. Sin pruebas de DoS/estrés ni fuerza bruta. Ventana de mantenimiento en laboratorio.
- **Procedimiento (3–7 pasos):**
 1. **Exportar** o documentar la configuración actual (reglas de firewall, NAT/port-forward, UPnP, administración remota, VPN).
 2. **Revisar reglas:** política por defecto “deny-all”, permitir solo tráfico necesario (allowlist), revisar DMZ↔LAN y WAN↔DMZ.
 3. **Gestión segura:** confirmar que la consola solo es accesible desde red de administración, credenciales robustas, MFA (si disponible), y *administración remota por WAN* deshabilitada.
 4. **Validar exposición** desde un host externo de laboratorio con **nmap -sV -Pn <IP WAN/host publicado>** para confirmar que solo hay puertos esperados (p. ej., 443 si procede).
- **Herramientas:** Consola Askey (config/backup), **nmap** (descubrimiento no intrusivo), visor del SIEM (Wazuh/Elastic/Graylog) para confirmar ingestión.
- **Criterios de aceptación (PASS/FAIL):**
 - Sin administración remota por WAN; gestión solo desde red de administración.
 - Puertos WAN expuestos = únicamente los justificados.
 - Política “deny-all” y allowlist explícita en reglas; NAT sin redirecciones innecesarias.
 - Syslog activo hacia SIEM; eventos del router visibles y con timestamp correcto.

Respuestas 4

A continuación, detallo las auditorías realizadas de los activos clave:

srvprod1

- **Zona:** LAN
- **Activo:** Servidor principal LDAP — Dell PowerEdge R740 — 192.168.1.6
- **Tipo de auditoría seleccionada:** Auditoría de red
- **Justificación de prioridad:** El servidor LDAP es el núcleo de autenticación de usuarios y grupos. Validar su integración en la red, segmentación, puertos autorizados y ausencia de exposición accidental reduce el riesgo de movimiento lateral y escalación en la LAN, garantizando control de acceso centralizado fiable
- **Alcance y limitaciones:** Comunicación LDAP/LDAPS, ACLs, segmentación LAN, revisión de puertos, reglas de firewall interno. Sin explotación activa ni modificación de configuración. Ventana de bajo impacto.
- **Procedimiento:**
 1. **Mapear puertos y servicios** escuchando en el servidor (netstat, nmap desde LAN).
 2. **Validar aislamiento por ACL:** solo hosts autorizados pueden consultar LDAP. (ufw, firewallld, iptables)
 3. **Comprobar protocolos seguros** (LDAPS/StartTLS).
 4. **Revisar logs de acceso** y fallos de autenticación.
- **Herramientas:** nmap, iptables, firewallld, audit, /var/logs/, journalctl.
- **Criterios de aceptación (PASS/FAIL):**
 - LDAPS activo y LDAP plano deshabilitado.
 - Solo segmentos autorizados acceden al puerto 636/389.
 - No hay puertos innecesarios expuestos.
 - firewall activo.

router WAN

- **Zona:** Perimetral DMZ
- **Activo:** Conexión a Internet — Fortinet FortiGate 200E — 172.16.1.1
- **Tipo de auditoría seleccionada:** Seguridad perimetral
- **Justificación de prioridad:** El router WAN es el punto de entrada y salida hacia Internet, siendo crítico para la protección ante ataques externos y control de tráfico hacia la red interna. Validar su configuración perimetral reduce riesgo de intrusión, movimiento lateral y exposición de servicios innecesarios.
- **Alcance y limitaciones:** Revisión de ACL, NAT, rutas, administración remota, VPN y logs. Validación desde red de gestión y desde host externo controlado. Sin explotación, stress test ni DoS. Acceso a consola y exportación de configuración en ventana autorizada.
- **Procedimiento:**
 1. **Exportar configuración** y revisar políticas ACL, NAT, VPN, logging, gestión remota.
 2. **Revisar política de filtrado:** deny-all + allowlist, segmentación WAN-DMZ-LAN.
 3. **Confirmar administración** solo desde red segura.
 4. **Revisar NAT y políticas de puerto expuesto;** eliminar reglas innecesarias
 5. **Confirmar logging** activo hacia SIEM.
- **Herramientas:** FortiGate GUI/CLI, nmap, Syslog / SIEM.
- **Criterios de aceptación (PASS/FAIL):**
 - Acceso admin solo desde red segura.
 - Solo puertos esenciales expuestos.
 - Envío al SIEM y timestamps correctos
 - Sin port-forward o DMZ general; solo servicios mínimos y documentados

firewall1

- **Zona:** Perimetral DMZ
- **Activo:** Firewall IDS/IPS — Fortinet FortiGate 600E — 172.16.1.5
- **Tipo de auditoría seleccionada:** Seguridad perimetral
- **Justificación de prioridad (2–4 líneas):** Como punto crítico perimetral, su revisión asegura que las reglas protejan adecuadamente la DMZ y el tráfico hacia Externo/interno, evitando exposición no deseada y accesos indebidos. Una brecha en este equipo comprometería toda la red.
- **Alcance y limitaciones:** Revisión config y reglas, administración, servicios habilitados, IPS/WAF activación. Sin pruebas destructivas, sin DoS. Acceso a consola y exportación de configuración en ventana autorizada.
- **Procedimiento:**
 1. **Exportar configuración** y revisar políticas WAN - DMZ - LAN.
 2. **Validar política** deny-all por defecto y reglas explícitas.

3. **Confirmar administración** solo desde red segura.
 4. **Ejecutar escaneo** externo controlado nmap para validar servicios expuestos.
- **Herramientas:** FortiGate GUI/CLI, nmap, Syslog / SIEM.
 - **Criterios de aceptación (PASS/FAIL):**
 - Acceso admin solo desde red segura.
 - IDS/IPS activo y actualizado.
 - Solo puertos esenciales expuestos.
 - Regla por defecto DENY.

NAS1

- **Zona:** DMZ LAB
- **Activo:** NAS / VAULT — EMC Unity XT 380 — 172.16.2.1
- **Tipo de auditoría seleccionada:** Auditoría legal (Compliance, protección de datos y PI)
- **Justificación de prioridad:** El NAS contiene planos, backups y documentación sensible. Es prioritario validar cumplimiento en protección de datos y propiedad industrial, asegurando medidas adecuadas para evitar fuga o acceso indebido, en línea con GDPR / ENS / ISO 27001.
- **Alcance y limitaciones:** Revisión cifrado, acceso mínimo, retención, registros. Sin tocar datos ni realizar restauraciones salvo pruebas controladas. Sin modificación de configuración. Ventana de bajo impacto.
- **Procedimiento:**
 1. **Verificar cifrado** de los datos.
 2. **Revisar ACLs** por roles.
 3. **Revisar políticas de retención / backup / purgado.**
 4. **Revisar logs de acceso** y fallos de autenticación.
 5. **Verificar avisos legales** y procedimientos de acceso a evidencias.
- **Herramientas:** EMC Unisphere, auditoría permisos CIFS/NFS, documentas.
- **Criterios de aceptación (PASS/FAIL):**
 - Datos cifrados.
 - Acceso mínimo, con registro.
 - Retención documentada.
 - Control contractual y política PI.

scada

- **Zona:** Smart Factory
- **Activo:** SCADA — Siemens IPC647G — 10.0.0.11
- **Tipo de auditoría seleccionada:** Auditoría forense (preparación post-incidente y registros)
- **Justificación de prioridad:** En entornos OT se evita intrusión activa. El objetivo es garantizar capacidad de respuesta, registro y trazabilidad ante incidentes industriales. En SCADA, disponibilidad e integridad son prioritarias frente a explotación ofensiva
- **Alcance y limitaciones:** Revisión logging WinCC, políticas USB, users locales, backups forenses. Sin escaneo activo, sin explotación, sin interrupción producción. Entorno productivo, horario controlado.
- **Procedimiento:**
 1. **Validar logs locales del SCADA** y exportación a servidor seguro.
 2. **Revisar controles** para evidencias (hash, retención, backup)
 3. **Confirmar bloqueo de USB** y cuentas locales.
 4. **Simular incidente leve** (login fallido) y validar traza.
- **Herramientas:** WinCC Audit, visor eventos Windows, políticas OT/USB, SIEM.
- **Criterios de aceptación (PASS/FAIL):**
 - Logs completos, inalterables y con retención definida.
 - USB deshabilitado.
 - Registros traza login/acciones operario.
 - Evidencias exportadas a repositorio seguro.